

Inside the Machine: Operating System Security & Malware

CS 474 — Computer Security (3 cr) · 2026-2027 · Class 5 · Thursday, October 22, 2026

Hour 1 — lecture in five lessons · 60 minutes

Block: Security Domains & Technologies (brought forward) · Reading: Easttom, Ch. 5 + Ch. 9

Cyber.SoHo Educational Hub — From the Industry to the Classroom

The one FACT to remember

1. Your weekly work is not homework on the side — it **IS** the project, and the project **IS** your exam preparation
2. Mid-Term: Thursday, November 19, 2026 = Milestone 1 · Final: Thursday, January 21, 2027 = Milestone 2
3. Same BlueFern Trading Inc. scenario, same kinds of decisions as every Binder Part
4. **Binder Part 5 — Malware Playbook & Hardening** — due Wednesday, October 28, 2026, 23:59
5. **LO** (learning outcome) 3 — *devise standard responses when spyware and malware occur* — is examined on the Mid-Term: Part 5 is the rehearsal
6. No malicious code is ever executed in this course: screenshots, logs and timelines only

The lecture hour — five lessons on the clock

Lesson	Time	Talk	Then… (micro-activity)
1 — The eight malware families	0:00 – 0:14	10 min	Flash-cards: the 8 families (4 min)
2 — How malware gets in and how it hides	0:14 – 0:26	8 min	Visualization: the ransomware timeline on one line (4 min)
3 — Operating-system security fundamentals	0:26 – 0:43	12 min	Short practical: read an ls -l listing and a local-users list (5 min)
4 — Standard responses when malware occurs	0:43 – 0:52	7 min	Fun quiz: 'first action?' for 3 mini-incidents (2 min)
5 — Hardening and endpoint protection	0:52 – 1:00	5 min	One quiz item (1 min) + Zen break (2 min)

By the end of this hour you will be able to

1. Classify malicious software into one of **eight families** from three observable criteria — and say why the family changes the response
2. Describe the **five infection vectors** that bring malware into a small company, and the **persistence** and **obfuscation** techniques that keep it there
3. Read the **five security settings** of an operating system — accounts, permissions, services, patching, logging — on Windows and on Linux, and spot the dangerous ones
4. Apply the **six-step standard response** — isolate, identify, contain, eradicate, recover, learn — to a malware incident at BlueFern Trading Inc. (**LO** (learning outcome) 3)
5. Specify a **hardening baseline** and an endpoint-protection stack, and explain why tested off-line backups defeat ransomware

Legal and ethical notice — read before any lab

1. All laboratory work is performed on the lab systems and the fictional BlueFern Trading Inc. scenario only, with explicit authorization

2. Unauthorized access to, or interference with, computer systems is a criminal offence — Criminal Code of Canada s. 342.1 · 18 U.S.C. § 1030 (**CFAA** (Computer Fraud and Abuse Act)) · **EU** (European Union) Directive 2013/40/EU · Spain, Ley Orgánica 10/1995 — regardless of intent

3. Never test a system you do not own or do not have written permission to test

4. Malware samples are **never** downloaded, shared or executed in this course (Legal Notice, sections 7.3 and 7.8)

5. Check every link with VirusTotal before you click (Legal Notice, section 14.2 and Annex C)

6. Full terms: Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0) — https://cyber-soho.github.io/prevmon/00.01.%20cyber.soho%20-%20legal.html

1

Lesson 1 — The eight malware families

How each one spreads and what it does — three questions that classify any sample

0:00 – 0:14 · 10 minutes + flash-cards

What malware is

1. **Malware** = malicious software: a program inserted into a system **without the owner's consent** to damage data, run intrusive or destructive code, or compromise confidentiality, integrity or availability

2. Source of the definition: **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-83 Rev. 1 — Guide to Malware Incident Prevention and Handling

3. Three parts to keep: it is a **program** · it runs **without consent** · it is defined by its **intent**, not its size or language

4. A **technique** (phishing, password guessing — Class 3) is a human action; malware is the **tool** the technique delivers

5. Keep the two apart in your Binder: the technique delivers, the tool does the damage

Three questions that classify any sample

1. Thousands of named samples — only a handful of families; classify by **what it does**, never by its name
2. **Q1 — Self-replication:** does it copy itself to other files or computers without a person doing the copying?
3. **Q2 — Host dependency:** does it need a host — another program, a document, a user action — to run at all, or is it stand-alone?
4. **Q3 — Goal of the payload:** the **payload** is the code that does the intended damage — destroy · encrypt · steal · control · hide · advertise · wait for a condition
5. The three answers give the family; the family tells you how fast it grows, where to look, and **what to do first** (Lesson 4)

The eight families (1/2)

1. **Virus** — attaches to a host (program, boot sector, macro document); replicates **only when a person opens the host**; spreads at the speed of human behaviour · Q1 yes · Q2 yes

2. **Worm** — stand-alone; replicates across the network **by itself** through a vulnerable service or weak passwords · Q1 yes · Q2 no
   - WannaCry, May 2017: 200,000+ computers in days through **SMB** (Server Message Block) version 1 — patched by Microsoft two months earlier

3. **Trojan** — presents itself as something useful or expected (installer, game, invoice); does **not** replicate; the user runs it once; opens a **backdoor** or downloads more malware · a **RAT** (remote access trojan) gives interactive control

4. **Ransomware** — encrypts files with a key only the attacker holds (or locks the screen) and demands payment; **double extortion** = data copied out first; arrives by phishing, exposed **RDP** (Remote Desktop Protocol), or carried by a worm

The eight families (2/2)

1. **Spyware / adware** — collects information without consent (**keylogger**, screenshots, saved passwords) / shows unwanted advertisements; often bundled with 'free' software from unofficial sites; installed on another person's device = a criminal offence

2. **Rootkit** — modifies the operating system itself (kernel modules, drivers, firmware, boot process) to **hide** other malware; runs with the highest privilege; detection needs an offline scan; removal = rebuild

3. **Botnet** — infected computers (**bots**) that take orders from a **C2** (command-and-control) server; regular contact = **beaconing**; used for spam, mining, credential stuffing, **DDoS** (distributed denial of service) · Mirai 2016: **IoT** (Internet of Things) devices with factory passwords

4. **Logic bomb** — code that waits for a condition (a date, an account removed from payroll) and then destroys; planted by an insider with legitimate access; no replication, no external arrival

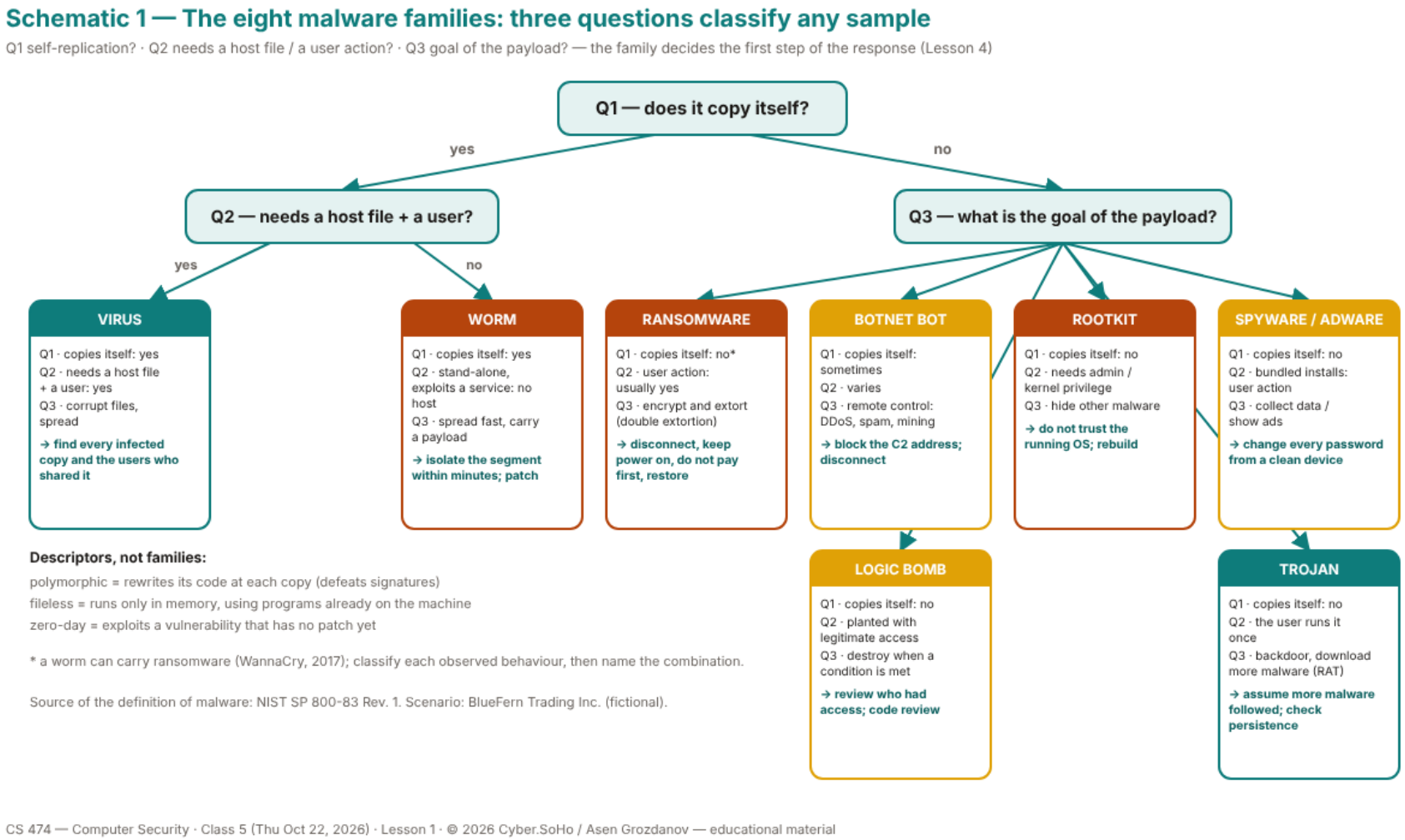
Words that are not families

1. **Polymorphic** — rewrites its own code at each infection, so no two copies look alike; defeats fixed signatures
2. **Fileless** — runs only in memory, using programs already on the machine (PowerShell); leaves no new file on disk
3. **Zero-day** — a vulnerability with no patch yet; malware that exploits it is 'zero-day malware'
4. These are **adjectives** that apply across families: a worm can be polymorphic, a trojan can be fileless
5. Real samples **combine** families: WannaCry = worm + ransomware; a trojan can install a rootkit and enrol the machine in a botnet
6. Classify each observed behaviour, then name the combination

Why the family changes the response

Family	Self-replicates?	Needs a host / user?	Goal	First consequence for the response
Virus	Yes	Yes — host file + a user	Corrupt, spread	Find every infected file and the users who shared it
Worm	Yes	No — exploits a service	Spread fast	Isolate the segment within minutes; patch
Trojan	No	Yes — the user runs it	Backdoor, download	Assume other malware followed; check persistence
Ransomware	No (unless in a worm)	Usually yes	Encrypt, extort	Disconnect, keep power on, do not pay first, restore
Spyware / adware	No	Yes — bundled installs	Collect data / ads	Change every password from a clean device
Rootkit	No	Admin / kernel privilege	Hide other malware	Do not trust the running OS; rebuild
Botnet bot	Sometimes	Varies	Remote control	Block the C2 address; disconnect
Logic bomb	No	Legitimate access	Destroy on a condition	Review who had access; code review

Schematic 1 — The eight families and the three questions



Real-life example 1 — Three alerts in one morning at BlueFern Trading Inc.

Lesson 1

- **Task:** classify three observed events with the three questions; write the first consequence for the response → the first line of the Malware Response Playbook (Exercise 5.1)

Event	Observed	Q1 copies itself?	Q2 host / user?	Q3 goal	Family
A — warehouse	Supplier's USB stick; photos.exe opened; now in the shared folder and on two PCs whose users opened it	Yes	Yes — a user opens it	Spread, corrupt	Virus
B — development	Laptop contacts the same unknown address every 60 s; CPU at 100 % at night	No	No — stand-alone	Remote control, mining	Botnet bot
C — finance	Invoice_0923.docm, Enable content; one day later every document is .locked + README_RESTORE.txt	No — spread with the shared password	Yes — the macro	Encrypt, extort	Ransomware (macro dropper)

Interactive example 1 · micro-activity · videos

Interactive example 1 — Malware family classifier

- A decision engine walks eight BlueFern events through Q1 → Q2 / Q3 → family
- The tree is drawn live; every decision is one line in the execution window
- Start / Pause (resumes from the exact decision), Step, Restart, Copy code, Download HTML / SVG / PNG
- File: app1_malware_family_classifier.html (in the module and the package)

Flash-cards (4 min) and videos

- Eight cards: show the family, the class answers the three questions, reveal the row
- ▶️ Every Type of Malware Explained in 8 Minutes — ByteMe Explained (8–10 min)
- ▶️ Malware — CompTIA A+ 220-1102 — 2.3 — Professor Messer (13 min)
- ▶️ Other Malware Types — CompTIA Security+ SY0-701 — 2.4 — Professor Messer (7.5 min)
- All links confirmed working on October 17, 2026 — check them on VirusTotal before clicking

2

Lesson 2 — How malware gets in and how it hides

Infection vectors, the macro that looked like an invoice, persistence and obfuscation

0:14 – 0:26 · 8 minutes + visualization

Infection vectors (1/2)

1. An **infection vector** = the path by which malware reaches a computer and is executed for the first time — a technical channel plus, very often, a human decision

2. **E-mail attachments and macros** — an Office document carries a **VBA** (Visual Basic for Applications) macro; *Enable content* runs it; the macro is a small **dropper / loader** that fetches the real malware
   - Since 2022 Office blocks macros in files carrying the **MOTW** (Mark of the Web) — attackers moved to archives, disc images, shortcut files, HTML smuggling: the vector changed its container, not its nature

3. **Drive-by downloads** — a web page exploits a browser or plug-in vulnerability, or imitates a prompt ('your browser is out of date'); advertising networks carry it (**malvertising**)

4. **Removable media** — a **USB** (Universal Serial Bus) stick with a file a curious user opens, or firmware that acts as a keyboard; autorun has been off since Windows 7, so the human step is necessary — and still happens

Infection vectors (2/2) — and why it looked like an invoice

1. **Supply chain** — the malware arrives inside something the company trusts: a vendor's update, a library from a public repository, a pre-installed component
   - NotPetya 2017 — the automatic update of an accounting program · 2020 — a vendor's build server compromised, its signed update installed a backdoor at thousands of customers

2. **Exposed services and weak credentials** — **RDP** (Remote Desktop Protocol), **SSH** (Secure Shell), **FTP** (File Transfer Protocol), a database listening on the Internet + a known vulnerability or a guessable password · BlueFern: SSH open to the world, BlueFern2019! everywhere

3. **Why it looked like an invoice:** subject 'Invoice 0923 — overdue', a display name copied from a real supplier, `Invoice_0923.pdf.exe` shown as `Invoice_0923.pdf` because known extensions are hidden by default

4. No vulnerability in the operating system was needed — the vulnerability was in the **default configuration** and in the absence of a second check; Lesson 5 removes the defaults instead of blaming the person

How malware stays — persistence

1. **Persistence** = the techniques that make malware start again after a restart — its own tactic in MITRE **ATT&CK** (Adversarial Tactics, Techniques and Common Knowledge) (TA0003)

2. **Windows:** registry Run / RunOnce keys · Startup folder · scheduled tasks · a new service · **WMI** (Windows Management Instrumentation) event subscriptions

3. **Linux:** cron jobs · systemd units · shell start-up files · a new account or an added SSH key

4. **The defender's counter-move:** know these places and look at them — Sysinternals **Autoruns** lists every Windows autostart location on one screen; `crontab -l`, `systemctl list-unit-files` on Linux

5. Each of these places writes an event: Event ID 7045 (new service), 4698 (new task), 4720 (new account) — Lesson 3

How malware avoids detection — obfuscation

1. **Obfuscation** = any transformation that keeps the behaviour and hides the appearance
2. **Packing** — the executable is compressed or encrypted with a small routine that unpacks it in memory; the file on disk matches no signature
3. **Polymorphism** — a different packed form for every copy
4. **Living off the land** — using programs already on the machine and signed by the vendor: PowerShell, `certutil`, `mshta`, `rundll32` — no new executable to detect
5. **Impairing defences** — switch the antivirus off, clear event logs, change file timestamps
6. Each technique is the reason one control in Lesson 5 exists (behavioural detection, allowlisting, forwarded logs, tamper protection)

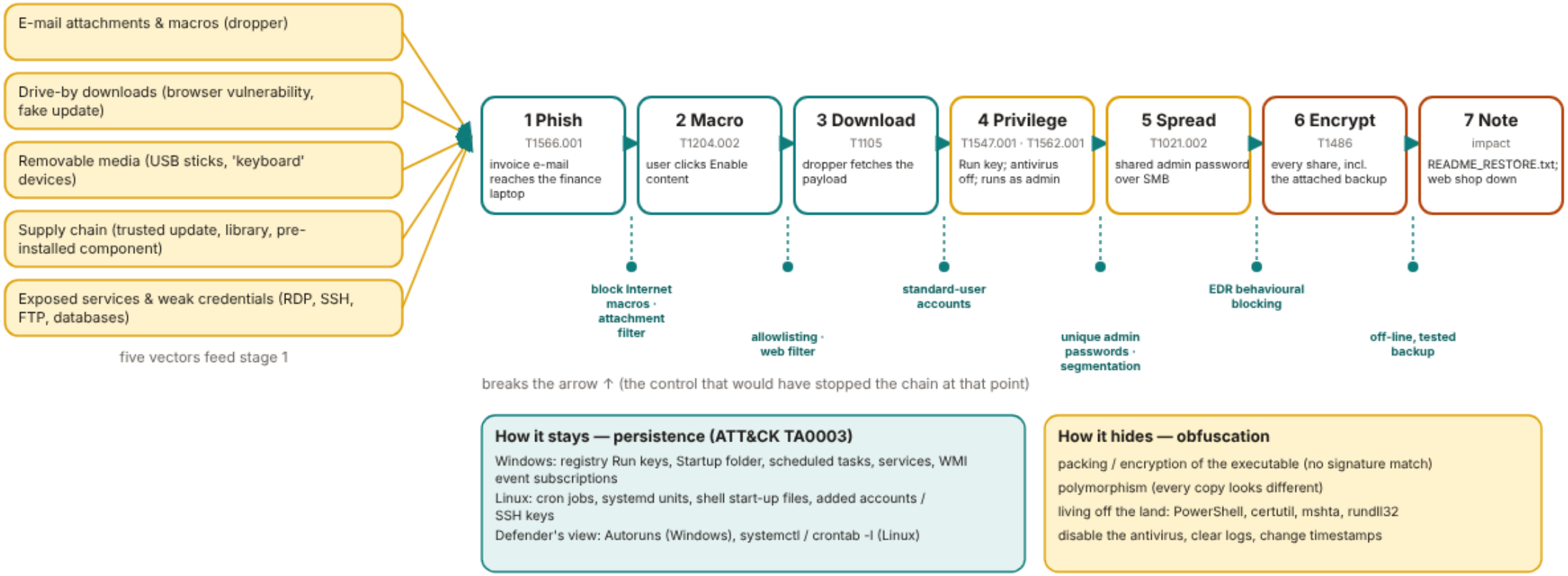
The ransomware timeline on one line

1. **1 Phish** — the invoice e-mail reaches the finance laptop (vector: e-mail attachment)
2. **2 Macro** — the user clicks *Enable content*; the VBA code runs (first execution)
3. **3 Download** — the macro fetches the ransomware from a web server
4. **4 Privilege** — already local administrator: adds a Run key, switches the antivirus off (persistence, defence evasion)
5. **5 Spread** — the attacker, through the backdoor, uses the shared administrator password to copy it to the file server and four laptops over **SMB** (Server Message Block)
6. **6 Encrypt** — every reachable share, including the attached USB backup drive
7. **7 Note** — README_RESTORE.txt in every folder; the web shop stops (its photos are on the same server)
8. Every arrow is a place where **one control** would have stopped the chain — the micro-activity, and the structure of Lesson 5

Schematic 2 — Five vectors and the seven-stage timeline

Schematic 2 — Five infection vectors and the ransomware timeline on one line

Every arrow between two stages is a place where one control would have broken the chain (Lesson 2 → Lesson 5)



How it stays — persistence (ATT&CK TA0003)

Windows: registry Run keys, Startup folder, scheduled tasks, services, WMI event subscriptions

Linux: cron jobs, systemd units, shell start-up files, added accounts / SSH keys

Defender's view: Autoruns (Windows), systemctl / crontab -l (Linux)

How it hides — obfuscation

packing / encryption of the executable (no signature match)

polymorphism (every copy looks different)

living off the land: PowerShell, certutil, mshta, rundll32

disable the antivirus, clear logs, change timestamps

CS 474 — Computer Security · Class 5 (Thu Oct 22, 2026) · Lesson 2 · technique ids from MITRE ATT&CK · © 2026 Cyber.SoHo / Asen Grozdanov — educational material

Real-life example 2 — Reconstructing the infection timeline

- **Task:** place seven observed facts on the timeline, name the technique (MITRE ATT&CK) and the one control that would have broken the chain → the 'what NOT to do' lines of Exercise 5.1 and the Class 6 tabletop timeline

Stage	Observed fact	Technique	Control that breaks it
1 Phish · Mon 09:12	Invoice_0923.docm from a look-alike supplier name	T1566.001	Attachment filtering; awareness
2 Macro · 09:31	Enable content clicked	T1204.002	Block Internet macros; visible extensions
3 Download · 09:31	svchost32.exe fetched and started	T1105	Allowlisting; web filtering
4 Privilege · 09:33	Run key added; antivirus off; runs as admin	T1547.001 · T1562.001	Standard-user accounts; tamper protection
5 Spread · 23:40	Shared admin password → FS01 + 4 laptops over SMB	T1021.002	Unique passwords; segmentation; EDR
6 Encrypt · Tue 02:05	Every share, incl. the attached USB drive	T1486	Least-privilege shares; off-line backups
7 Note · Tue 08:10	README_RESTORE.txt; web shop down	—	Separate the web shop from the file server

Interactive example 2 · micro-activity · videos

Interactive example 2 — Ransomware chain simulator

- Animates the seven stages across BlueFern's office network (finance laptop, four laptops, FS01, the USB drive)
- Six controls can be switched on; each breaks the chain at one stage — the window says which and why
- Start / Pause, Step, Restart, Copy code, Download HTML / SVG / PNG
- File: app2_ransomware_chain_simulator.html

Visualization (4 min) and videos

- Seven boxes on the board; the class names the control for each arrow
- ▶️ Attack Vectors — CompTIA Security+ SY0-601 — 1.5 — Professor Messer (10.5 min)
- ▶️ Macro-Based Attacks Explained — BlueHat CyberSec Academy (7–8 min)
- ▶️ How Do Cybercriminals Spread Malware? — Keeper Security (3 min)
- All links confirmed working on October 17, 2026

3

Lesson 3 — Operating-system security fundamentals

Accounts and privileges, file permissions, services, patching, logging — Windows and Linux side by side

0:26 – 0:43 · 12 minutes + short practical

What the operating system is for, from a security point of view

1. The **OS** (operating system) decides what every other program may do: it owns the processor, memory, disk and network and **mediates every request**
2. 'This process, for this user, wants to read that file / open that port — allowed or denied?' — the component that decides is the **reference monitor**
3. Almost every technique of Lesson 2 is an attempt to run with **more authority** than the reference monitor should have granted
4. Five settings decide whether it succeeds: **accounts and privileges · file permissions · services · patching · logging**
5. BlueFern has both systems: Windows laptops and a Windows file server in the office, a Linux server for the web shop

1 — Accounts and privileges

Windows

- Any member of the local **Administrators** group has full authority; a **standard user** runs programs and changes own files only
- **UAC** (User Account Control) keeps even an administrator at standard rights until an action needs elevation and the prompt is confirmed
- Check: `net localgroup Administrators` · `lusrmgr.msc` · is Guest enabled? · built-in Administrator (**SID** (security identifier) ending in -500) renamed and disabled?

Linux

- **root** (**UID** (user identifier) 0) has full authority; regular users have UID ≥ 1000
- `sudo` grants temporary root rights under the rules of `/etc/sudoers` and logs every use
- Check: `getent passwd` for UID 0 accounts other than root · the sudo group · accounts with a login shell that should not have one
- **Least privilege:** daily work as a standard user; elevate only for the specific action

- BlueFern: every laptop user is a local administrator 'to install printers'; one shared password for the router, the file server and the web-shop console; no **MFA** (multi-factor authentication) → one bad click runs as administrator and the shared password works on the file server

2 — File permissions

Linux — rwx and octal

- Owner · group · others × read · write · execute; `ls -l` prints ten characters: `-rwxr-x---`
- Octal: read = 4, write = 2, execute = 1 per set → `rwxr-x---` = **750**
- **777** (`drwxrwxrwx`) = world-writable: any account, including a compromised web service, can write there
- `chmod 750 folder` fixes it; `chown` changes the owner; on a folder, execute = may enter; the **setuid** bit (s) runs a program as its owner

Windows — NTFS ACL

- An **NTFS** (New Technology File System) **ACL** (access control list) lists entries granting Full control · Modify · Read & execute · Read · Write, with inheritance from the parent folder
- The Windows equivalent of 777: **Everyone: Full control** on a shared folder — BlueFern's file server, almost word for word
- A shared folder also has **share permissions**; evaluated together with NTFS permissions, the most restrictive wins

3 — Services · 4 — Patching

Services

- A **service** (Windows) or **daemon** (Linux) runs in the background, often privileged, often listening on a port
- Every listening service is part of the **attack surface**
- Last week's scan: FTP, SSH, two web ports and MySQL on the Internet — three should not be reachable at all
- Inventory → disable what is not needed → restrict the rest · `services.msc`, `Get-Service` · `systemctl list-units --type=service`, `ss -tlnp`

Patching

- A **patch** is a vendor's correction of a vulnerability; WannaCry's hole was patched on March 14, 2017 — the worm came on May 12
- Windows: **Patch Tuesday** (2nd Tuesday) and the **MSRC** (Microsoft Security Response Center) update guide · Linux: `apt update && apt upgrade`, unattended-upgrades
- **End of life** (**EOL** (end of life)) software gets no fixes: MySQL 5.5 (Class 4); Windows 10 since October 14, 2025 unless enrolled in **ESU** (Extended Security Updates)
- BlueFern's web server: 'last patched sometime in 2023' — the checklist needs a date **and** an owner

5 — Logging

1. **Windows Event Viewer** → **Security log**, one **Event ID** per kind of event: 4624 successful logon · **4625 failed logon** · 4720 user account created · 4732 member added to a local group · 4698 scheduled task created · System log: 7045 new service installed

2. Three of those are the persistence techniques of Lesson 2 — the log shows them the moment they happen

3. **Linux:** `/var/log/auth.log` (Debian / Ubuntu) or `journalctl -u ssh` — a failed SSH login reads `Failed password for invalid user admin from 198.51.100.7 port 51522`

4. A hundred such lines from one address in ten minutes = a password-guessing attack in progress

5. Logs help only if they are **kept** (retention), **protected** (an administrator can clear them — Event ID 1102) and **read** — Class 6 moves them off the machine into a central collector (**SIEM** (security information and event management))

Windows and Linux side by side

Setting	Windows	Linux	What you check	BlueFern finding
Privileged account	Administrators group; UAC; built-in Administrator (SID -500)	root (UID 0); sudo / sudoers	Who is an administrator; Guest / root login	Every laptop user is a local administrator
File permissions	NTFS ACL + share permissions	rwx owner / group / others; octal 750, 777	Everyone: Full control; 777 folders	Everybody reads everything on the file server
Services	services.msc; Get-Service	systemctl list-units; ss -tlnp	What runs, what listens, what is unnecessary	FTP, SSH, MySQL exposed
Patching	Windows Update; Patch Tuesday; MSRC	apt / dnf; unattended-upgrades	Last update date; EOL software	Web server last patched in 2023; MySQL 5.5 EOL
Logging	Security log 4624 / 4625 / 4720 / 4732 / 4698; System 7045	/var/log/auth.log; journalctl	Failed logons; new accounts, services, tasks	Nobody reads the logs; no collector

Schematic 3 — Five settings, Windows and Linux side by side

Schematic 3 — Operating-system security: five settings, Windows and Linux side by side

The reference monitor decides what every process may do; these five settings decide whether malware gets more authority than it should

Setting	Windows	Linux	What you check	BlueFern finding
1 Accounts & privileges	Administrators group · built-in Administrator (SID -500) · UAC elevation · Guest account · net localgroup Administrators, lusrmgr.msc	root (UID 0) · sudo governed by /etc/sudoers · regular users UID ≥ 1000 · getent passwd, id	who is an administrator; Guest / root login enabled?; stale accounts	every laptop user is a local administrator; one shared admin password; no MFA
2 File permissions	NTFS ACL: Full control / Modify / Read & execute / Read / Write · inheritance · share permissions (most restrictive wins)	rwx for owner / group / others · octal (r=4 w=2 x=1): 750 safe, 777 world-writable · chmod, chown · setuid bit	Everyone: Full control; world-writable folders; sensitive files readable by all	everybody reads everything on the file server; finance-export is 777
3 Services	services.msc · Get-Service · each listening service = attack surface	systemctl list-units --type=service · ss -tlnp (what listens on which port)	what runs, what listens, what is unnecessary	FTP, SSH and MySQL reachable from the Internet
4 Patching	Windows Update · Patch Tuesday (2nd Tuesday) · MSRC Security Update Guide · Windows 10 end of support Oct 14, 2025 (ESU)	apt update && apt upgrade · dnf · unattended-upgrades · distribution security notices	last update date; EOL software; an owner and a date for updates	web server last patched in 2023; MySQL 5.5 end of life
5 Logging	Event Viewer → Security log: 4624 logon, 4625 failed logon, 4720 user created, 4732 added to group, 4698 task created · System log: 7045 new service	/var/log/auth.log ('Failed password for … from …') · journalctl -u ssh · /var/log/syslog	failed-logon bursts; new accounts, services, tasks; retention; central collection	nobody reads the logs; no central collector; 14-hour gap unnoticed

CS 474 — Computer Security · Class 5 (Thu Oct 22, 2026) · Lesson 3 · © 2026 Cyber.SoHo / Asen Grozdanov — educational material

Real-life example 3 — Auditing the BlueFern file server

1. **Task:** decode an `ls -l` listing into octal and flag the dangerous entries; review the local-users list; count failed logins per source address in an auth-log excerpt → the same four findings as the Exercise 5.3 mini-lab

2. `drwxrwxrwx finance-export` → **777**, world-writable — any account can write there · fix `chmod 750` + the right group

3. `-rwsr-xr-x fixperms` → **setuid** root: whoever runs it runs as root · remove the bit unless justified

4. `-rw-rw-r-- payroll_2026.xlsx` → readable by everybody on the system · fix `chmod 640`

5. Windows: **Guest enabled**; `warehouse-tmp` (last logon 2024) still enabled **and** an administrator; `svc-backup` in Administrators — more than a backup job needs

6. auth.log: five failures from 198.51.100.7 in nine seconds (admin, root, test) = password guessing on a service that should not be reachable from the Internet · Windows twin: a burst of Event ID 4625 · contain: SSH behind the VPN, key-based login

Interactive example 3 · micro-activity · videos

Interactive example 3 — Permission decoder and login-failure scanner

- Part A decodes ls -l lines into octal, draws the nine bits and flags 777 / setuid / readable-by-all
- Part B reviews the local-users list (Guest, stale, unnecessary administrators)
- Part C scans auth.log line by line, counts failures per address, draws the bar chart, alerts at 5
- File: app3_permission_decoder_log_scanner.html

Short practical (5 min) and videos

- ls -l listing + Windows local-users list: find the two dangerous settings in each; one auth-log line: failed or accepted, from where?
- ▶️ Linux file permissions and chmod explained — Red Hat (11–12 min)
- ▶️ Windows Security Settings — CompTIA A+ 220-1102 — 2.5 — Professor Messer (8 min)
- ▶️ Windows Logon Events 4624, 4625, 4634 Explained — Infosec Wizard (14:53)
- All links confirmed working on October 17, 2026

4

Lesson 4 — Standard responses when malware or spyware occurs

Isolate → identify → contain → eradicate → recover → learn — the LO 3 playbook

0:43 – 0:52 · 7 minutes + fun quiz

Lesson 4

A standard response is a written sequence, not an improvisation

1. **LO** (learning outcome) 3: *devise standard responses in the case spyware and malware occurs*

2. A **standard response** — a **playbook** — is a numbered sequence of actions with a named role for each, written **before** the incident, so the person who finds the problem at 08:10 on a Monday does not have to think about what comes first

3. Six steps: **isolate · identify · contain · eradicate · recover · learn**

4. They map onto the incident-response life cycle of **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-61 (preparation, detection and analysis, containment, eradication and recovery, post-incident activity) — Class 6 covers it in full

5. Exercise 5.1 expands the six steps into 8–12 numbered steps for BlueFern Trading Inc.

Steps 1–3 — isolate, identify, contain

1. **1 Isolate** — unplug the cable, switch off Wi-Fi or the switch port; stops the spread and the beaconing · **do not power off**: volatile memory holds evidence (processes, connections, sometimes keys) and some families react to a shutdown

2. **2 Identify** — which family (Lesson 1), which hosts, since when, how it arrived (Lesson 2): **AV** (antivirus) / **EDR** (endpoint detection and response) console, the note, file names, Security log (4625 bursts, 4720, 7045), auth.log, the mail gateway · write the facts down with times — the start of the timeline
   - A worm → every connected host is suspect · a rootkit → the OS cannot be trusted to describe itself

3. **3 Contain** — disable compromised accounts; change the shared administrator password **from a machine you trust**; block the **C2** (command-and-control) address at the firewall; take shares offline; preserve: copy the note, the sample and the logs to labelled removable media and lock it away
   - The **IOC** (indicator of compromise)s — hashes, the C2 address, the sender — are what you search for on the other 29 laptops

Steps 4–6 — eradicate, recover, learn

1. **4 Eradicate** — remove the malware and the way it came in: every autostart entry (Autoruns; cron and systemd units) and the files they point to · rootkit or ransomware → **wipe and reinstall** from known-good media — cleaning a compromised OS in place is almost always wasted time · close the vector (macro policy, admin rights, unpatched service)

2. **5 Recover** — restore from a **clean** backup: taken before the infection, kept off-line, verified by a test restore · order of business priority: web shop first ($3,000 per hour), file server, laptops · reconnect under close monitoring; search for the IOCs for weeks
   - No clean backup = this is where the weekly, never-tested USB drive shows its real value

3. **6 Learn** — the incident report within days: timeline, root cause, cost, what worked, what did not, the changes to make (Lesson 5) · update the playbook, train · what the payment gateway, the insurer and — under Québec's Law 25 and **PIPEDA** (Personal Information Protection and Electronic Documents Act) — the privacy regulator and the affected customers may require

Who does what at BlueFern — and what nobody does

Roles

- **Discoverer** (any employee): disconnects the machine, leaves it on, calls IT, touches nothing else
- **IT lead**: incident lead — runs steps 1 to 5, keeps the timeline
- **CEO (chief executive officer) / COO (chief operating officer)**: money, customers, the press — the only voice to journalists
- **CFO (chief financial officer)**: the payment gateway and the insurer
- **External help**: an incident-response firm; the police (**RCMP** (Royal Canadian Mounted Police), Canadian Centre for Cyber Security); the privacy regulator when personal data is involved

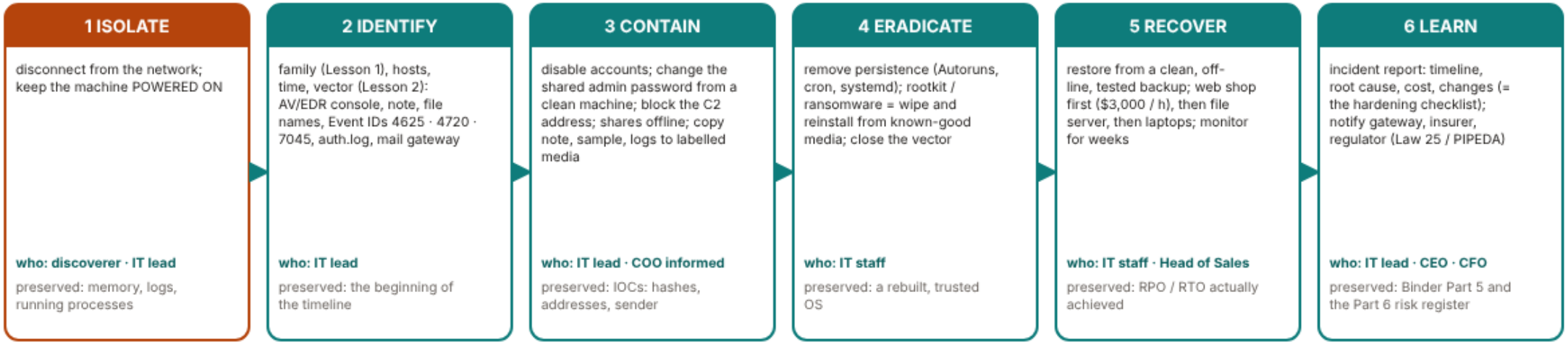
Nobody, in the first hour

- Pays the ransom (no guarantee of a working key; funds crime; may breach sanctions rules; the stolen copy stays with the attacker)
- Powers machines off
- Reconnects the backup drive to an infected server
- Wipes a machine before evidence is preserved
- Posts about the incident on social media
- **Spyware variant:** assume every password typed on that machine is known — change them all, from a different, clean device, first

Schematic 4 — The six-step standard response

Schematic 4 — The six-step standard response to malware (LO 3 playbook)

Written before the incident, with a role per step — maps onto the NIST SP 800-61 incident-response life cycle (Class 6)



NEVER in the first hour — the four tempting decisions

- × Power the machine off: volatile memory (processes, connections, sometimes keys) is lost; some families react to a shutdown.
- × Reconnect the backup drive to an infected server 'to see if it still works': it is encrypted too.
- × Pay the ransom first: no guarantee of a key, funds crime, may breach sanctions rules, the stolen copy stays with the attacker — management decides after containment.
- × Wipe a machine before evidence is preserved, or post about the incident on social media: the CEO is the only voice to the press.

CS 474 — Computer Security · Class 5 (Thu Oct 22, 2026) · Lesson 4 · © 2026 Cyber.SoHo / Asen Grozdanov — educational material

Real-life example 4 — Monday 08:10, the ransom note: the decision log

- **Task:** run the six steps as decisions for BlueFern; record time, step, decision, who, effect → Exercise 5.1 (the 8–12-step playbook) and the Class 6 tabletop (Exercise 6.1, with injects at T+20 / T+30 / T+40)

Time	Step	Decision	Who	Effect
08:12	1 Isolate	FS01 + 5 laptops unplugged, left on	IT lead; discoverers	Spread stops; evidence preserved
08:20	2 Identify	Note; .locked; Run key; AV stopped 09:33; 2 recipients	IT lead	Scope, vector, entry point known
08:45	3 Contain	Accounts disabled; password changed from a clean PC; C2 blocked; evidence copied and locked	IT lead; COO	Access revoked; IOCs ready
09:30	do not	CEO asks to reconnect the USB drive — refused	IT lead; CEO	Drive already encrypted (T+30 in Class 6)
10:00	4 Eradicate	Wipe + reinstall; macro policy + admin rights changed; 25 laptops scanned	IT staff	Malware and vector gone
Day 2	5 Recover	Three-week-old export restored; web shop first	IT; Head of Sales	Web shop back in 26 h; 3 weeks of documents lost
Day 5	6 Learn	Report; 15 changes; gateway and regulator informed	IT lead; CEO; CFO	Binder Parts 5 and 6

Interactive example 4 · fun quiz · videos

Interactive example 4 — Response playbook runner

- Eight hosts; while nothing is isolated the malware reaches one more host per tick
- The six steps run in order; three meters: hosts encrypted, evidence preserved, data recoverable
- Two tempting mistakes can be switched on (power off; reconnect the backup) — the meters show their cost
- Copy decision log for the Binder · File: app4_response_playbook_runner.html

Fun quiz (2 min) and videos

- First action? (1) ransom notes on the file server (2) pop-ups and a slow sales laptop (3) 'I enabled the macros five minutes ago and nothing happened'
- ▶️ Incident Response — CompTIA Security+ SY0-701 — 4.8 — Professor Messer (9 min)
- ▶️ Removing Malware — CompTIA A+ 220-1102 — 3.3 — Professor Messer (8 min)
- ▶️ The 6 Steps of the Incident Response Life Cycle — Cyber Gray Matter (7.5 min)
- All links confirmed working on October 17, 2026

5

Lesson 5 — Hardening and endpoint protection

Baseline configurations, antivirus and EDR, application allowlisting, and backups as the ransomware antidote

0:52 – 1:00 · 5 minutes + quiz item + Zen break

Hardening — reducing the attack surface by configuration

1. **Hardening** = configure the system so that it exposes the smallest possible attack surface: remove or disable what is not needed, restrict what remains, record the result as a **baseline configuration** every machine of that type must match

2. You do not invent the baseline: the **CIS** (Center for Internet Security) publishes the **CIS Benchmarks** — step-by-step guides for Windows, Linux, browsers, databases, cloud — and the CIS Critical Security Controls; controls 1–6 cover the five settings of Lesson 3

3. **Laptop baseline in short:** standard user for daily work + unique, centrally managed admin password · automatic updates with a monthly check · Internet macros blocked, extensions visible · unneeded services off · disk encryption (BitLocker / **LUKS** (Linux Unified Key Setup)) · screen lock at 10 min · USB storage restricted · logging on and forwarded

4. **File server, in addition:** share permissions by role (the **RBAC** (role-based access control) matrix of Part 2) · no Everyone: Full control · no world-writable folder · Guest disabled · the backup drive **not** permanently attached

Endpoint protection — antivirus, EDR, allowlisting

1. **Antivirus / anti-malware** detects in three ways: **signature-based** (patterns and hashes of known samples — fast, precise, blind to packed, polymorphic or new samples) · **heuristic / behavioural** (what the program does — a process rewriting hundreds of documents in a minute is stopped whatever its name) · **sandboxing** (run the attachment in isolation first)

2. Windows ships Microsoft Defender, which does all three; the mistake is leaving it disabled, out of date or excluded from the folders that matter

3. **EDR (endpoint detection and response)** — an agent records process starts, file changes, registry writes and network connections, correlates them into detections ('Word started PowerShell, which downloaded an executable') and lets IT **isolate a machine remotely** — step 1 of the playbook from a desk

4. **Application allowlisting** (older term: whitelisting) reverses the logic: only approved programs run — by publisher signature, path or hash · `Invoice_0923.pdf.exe` is not on the list, so it never starts · Windows: AppLocker, **WDAC** (Windows Defender Application Control) · Linux: restricted sudo, `noexec` mounts, AppArmor / SELinux

Backups — the control that defeats ransomware

1. Every control above lowers the **probability** of an infection; one control removes the attacker's **leverage**: a backup the attacker cannot reach

2. **3-2-1:** three copies of the data · on two different types of media · one copy off-site — and, since ransomware learned to look for backups, that copy **off-line or immutable** (cannot be modified or deleted for a set period)

3. BlueFern today: one USB drive permanently attached, copied weekly 'by whoever remembers', never tested — encrypted with the server; the newest copy may be seven days old; nobody knows how long a restore takes

4. **RPO (recovery point objective)** = the maximum data loss the company accepts (time since the last clean copy) · **RTO (recovery time objective)** = the maximum time to restore — known only after a test restore

5. A backup that has never been restored is a hypothesis · Class 6 turns RPO and RTO into a design (Exercise 6.3)

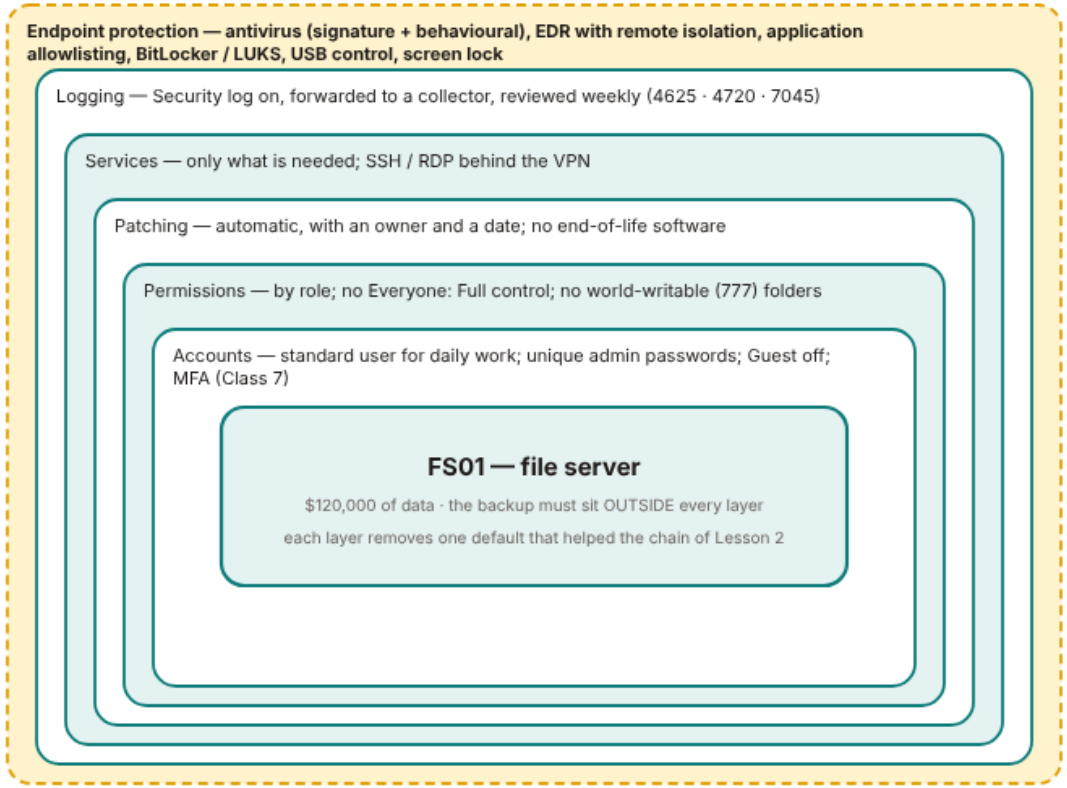
The checklist in one line — Exercise 5.2

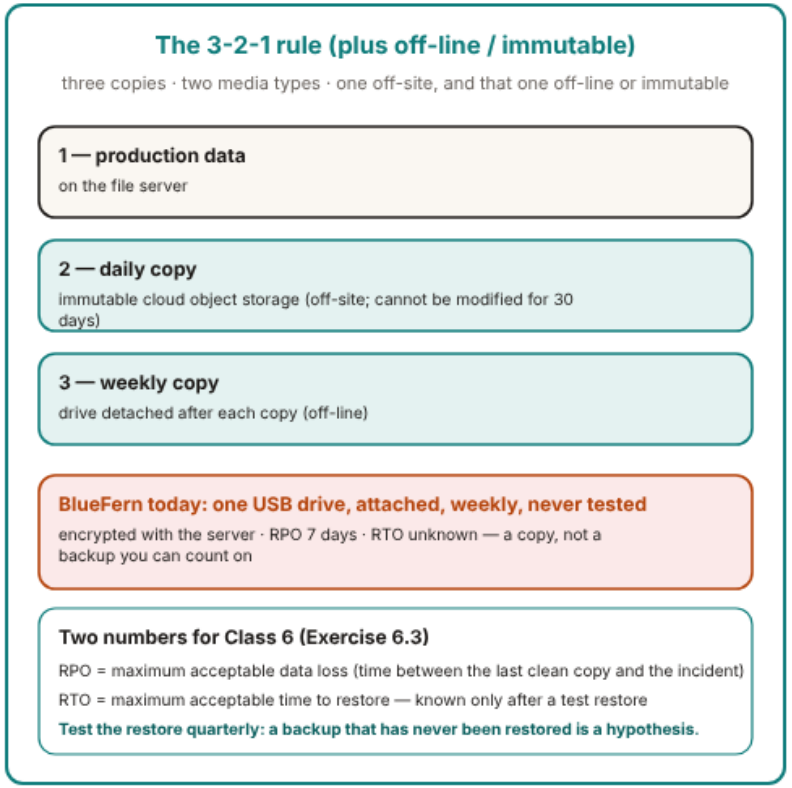
1. **Accounts:** remove local administrator rights · unique admin password per machine · Guest off, stale accounts removed
2. **Patches:** automatic, with an owner and a date · no end-of-life software
3. **Services:** only what is needed · SSH / RDP behind the VPN
4. **Permissions:** shares by role · Internet macros blocked, extensions visible · application allowlisting
5. **Logging:** on, forwarded, reviewed weekly (4625 · 4720 · 7045)
6. **Backup:** 3-2-1 with an off-line or immutable copy · daily · tested quarterly · written RPO / RTO
7. **Endpoint:** antivirus on and tamper-protected · EDR with remote isolation · disk encryption · USB restricted, screen lock
8. Fifteen items, each with a one-line *why* — the second half of Binder Part 5

Schematic 5 — Hardening layers and the 3-2-1 backup rule

Schematic 5 — Hardening layers around the file server, and the 3-2-1 backup rule

Hardening lowers the probability of an infection; a backup the attacker cannot reach removes the leverage





Baseline source: CIS Benchmarks (Center for Internet Security) — fifteen items selected for BlueFern's file server and laptops (Exercise 5.2)

CS 474 — Computer Security · Class 5 (Thu Oct 22, 2026) · Lesson 5 · © 2026 Cyber.SoHo / Asen Grozdanov — educational material

Real-life example 5 — Would the backup have saved us?

- **Task:** apply the 15-item checklist to the file server and the laptops, compute an exposure score before and after, and compare the weekly attached-USB backup with a 3-2-1 design in days of data lost → Exercise 5.2, then the Class 6 backup plan and risk register

	A — today: weekly copy, USB drive attached, never tested	B — 3-2-1: daily immutable cloud copy + weekly detached drive, tested
Ransomware strikes on day 10	Drive encrypted with the server	Immutable copies and the detached drive untouched
Last clean copy	None (or a three-week-old export)	Day 9 (cloud)
Data lost (RPO achieved)	Everything — $120,000 of file-server data — or three weeks	One day
Restore time (RTO)	Unknown — never tested	Known — tested last quarter
Exposure score (15 items)	100 — nothing applied	Falls with each item; two numbers for the Class 6 risk register

Interactive example 5 · quiz item · videos

Interactive example 5 — Hardening score and backup calculator

- Tick checklist items: the exposure scores of the server and the laptops recompute and the bars redraw
- The fourteen-day calendar: scenario A vs scenario B, ransomware on a chosen day; data lost and RPO per scenario
- Start / Pause, Step (one day), Restart, Copy, Download HTML / SVG / PNG / checklist CSV
- File: app5_hardening_backup_calculator.html

Quiz item (1 min), Zen break (2 min), videos

- 'The attached, weekly USB drive — which part of 3-2-1 does it satisfy?' — a copy, not a backup you can count on
- ▶️ EDR vs. EPP vs. NGAV — IBM Technology (3.5 min)
- ▶️ 3-2-1 Backup Rule Explained — IBM Technology (10–11 min)
- ▶️ Hardening Techniques — CompTIA Security+ SY0-701 — 2.5 — Professor Messer (12 min)
- All links confirmed working on October 17, 2026

Hours 2–3 and at home — Binder Part 5 (summary only)

1. **Exercise 5.1 — Malware Response Playbook** for BlueFern Trading Inc. (ransom note on the file server): 8–12 numbered steps, who does what, what NOT to do, who is informed and when
2. **Exercise 5.2 — Hardening checklist:** 15 concrete items for the file server and the staff laptops, each with a one-line 'why'
3. **Exercise 5.3 — Mini-lab** on the lab VM: create a low-privilege user, fix a world-writable folder, list the running services, find the failed-login lines (Windows: local users, Services, Event Viewer ID 4625) — paper-lab outputs in the module as fallback
4. **At home (2 h):** Easttom Ch. 5 + the OS-hardening / antivirus sections of Ch. 9; finish Binder Part 5 (playbook + checklist + half-page lab log)
5. **Due:** Wednesday, October 28, 2026 — 23:59 · LO 3 is examined on the Mid-Term: the playbook is the rehearsal
6. The exercise sheets are created separately in class — this slide is the summary

Key references (official sites — check each link on VirusTotal before clicking)

- **NIST SP 800-83 Rev. 1 — Guide to Malware Incident Prevention and Handling** https://csrc.nist.gov/pubs/sp/800/83/r1/final
- **NIST SP 800-61 Rev. 3 — Incident Response Recommendations** https://csrc.nist.gov/pubs/sp/800/61/r3/final
- **CIS Benchmarks — Center for Internet Security** https://www.cisecurity.org/cis-benchmarks
- **MITRE ATT&CK — Persistence (TA0003)** https://attack.mitre.org/tactics/TA0003/
- **CISA #StopRansomware Guide** https://www.cisa.gov/stopransomware/ransomware-guide
- **Canadian Centre for Cyber Security — Ransomware playbook (ITSM.00.099)** https://www.cyber.gc.ca/en/guidance/ransomware-playbook-itsm00099
- **Microsoft Learn — Event 4625 (an account failed to log on)** https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/auditing/event-4625
- **Microsoft Learn — Macros from the internet are blocked by default** https://learn.microsoft.com/en-us/deployoffice/security/internet-macros-blocked
- **Linux manual page — chmod(1)** https://man7.org/linux/man-pages/man1/chmod.1.html
- **No More Ransom** https://www.nomoreransom.org/
- **Easttom — Computer Security Fundamentals, 4th ed. (Pearson)** https://www.pearson.com/en-ca/subject-catalog/p/computer-security-fundamentals/P200000000230/9780137459674
- **Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0)** https://cyber-soho.github.io/prevmon/00.01.%20cyber.soho%20-%20legal.html



Thank you — see you in Hours 2 and 3

Binder Part 5 — Malware Playbook & Hardening — due Wednesday, October 28, 2026, 23:59

Next week, Class 6 (Thu Oct 29): When It Happens — Detection, Containment, Response & Recovery

Educational material — Cyber.SoHo / Asen Grozdanov · © 2026 Cyber.SoHo · All rights reserved · Legal Notice v2.0: https://cyber-soho.github.io/prevmon/00.01.%20cyber.soho%20-%20legal.html

Educational Hub © 2026 | From the Industry to the Classroom — Building the IT’s Future, Today and Together ! ALL Rights Reserverd